

Appendix D Evaluation Instruments

Part 1 Policy Evaluation Rubric

D.1 Scope

This document outlines the only scoring instrument used in the study. Using the Policy Evaluation Rubric, each policy was scored one requirement area at a time across PCI DSS v4.0.1 Requirements 7, 8, 10, and 12. Therefore rubric sets out the criteria, the bands and the scoring rules by which every policy was scored during Phase 2 [by LLM models], Phase 4 [by the human reviewers] and Phase 5 [by the researcher].

Policies are identified by code rather than by name. In a code such as P1b the letter records the prompt condition under which the policy was written: a is standard-reference, b is compliance-framing, and c is the control condition, in which no organisational scenario was supplied.

A suffix of -R marks a policy revised at Phase 3, so P1b-R is P1b after revision, and A(x) denotes the audit of policy x. The digit distinguishes the two models; which model produced which policy is not disclosed to human reviewers.

In order to carry out the policy evaluation, the model and human reviewer need input from Appendix A and Appendix C, which outline the scenario brief and PCI DSS sub-requirements.

The rubric is built in two layers, one counted and one judged, and Figure D.1 shows how they combine into a single score. Each layer is set out in full in the sections that follow.

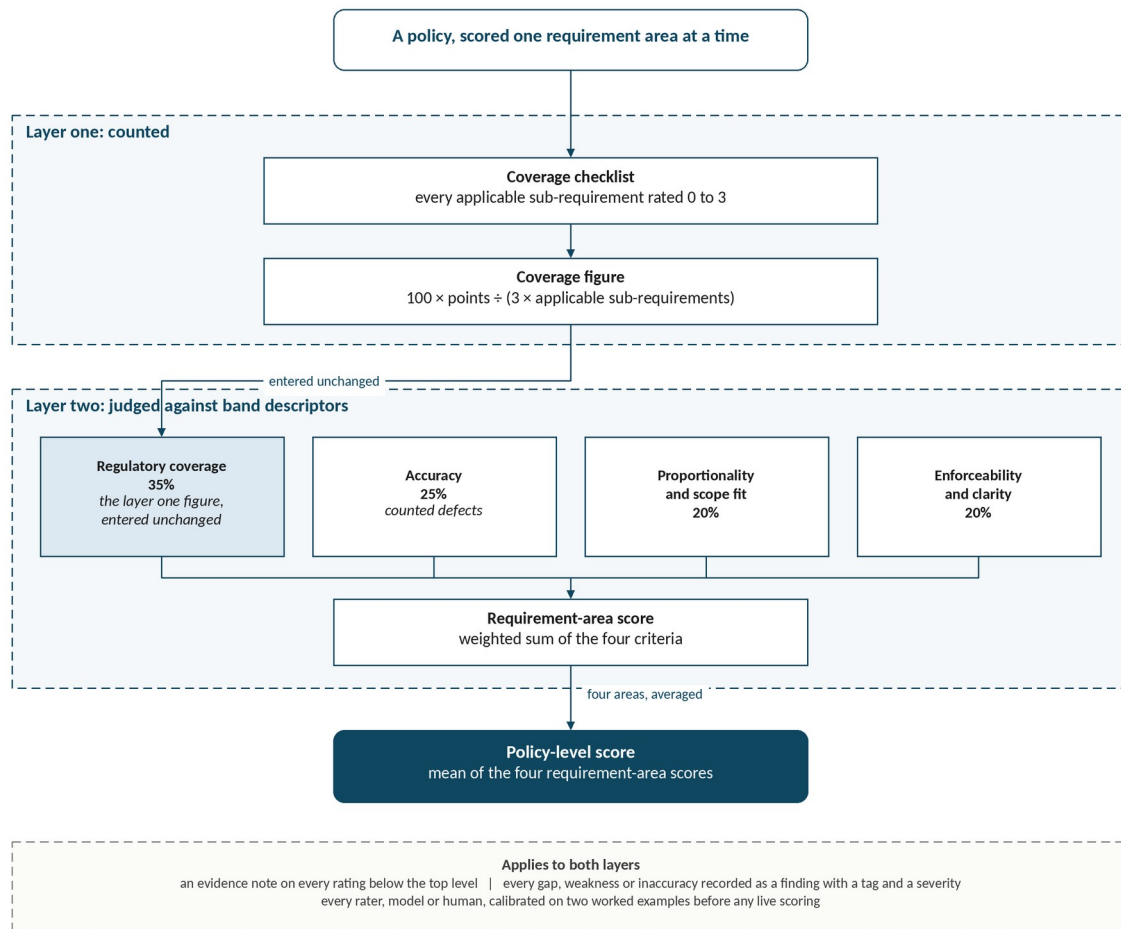


Figure D.1: The two layers of the rubric.

D.2 Layer one: the coverage checklist

For each requirement area the checklist lists every sub-requirement that applies to the organisation. The rater assigns one level to each item and nothing else; judgement about the quality of the wording belongs in layer two.

Level	Points	Definition
Fully addressed	3	The obligation is stated, with parameters at least as strict as version 4.0.1, and with an owner and a frequency where the sub-requirement implies them.
Largely addressed	2	The obligation is present, but one element is missing or is stated more weakly than the standard.
Partially addressed	1	The topic is mentioned, but the obligation is not stated in a form an assessor could test.
Not addressed	0	Absent in any form.
Not applicable	excluded	Outside the organisation's scope, or reserved to a later assessment. Removed from the denominator,

Level	Points	Definition
		not scored as zero. Sub-requirements the standard addresses to service providers, and those whose obligation is discharged in configuration, never reach the checklist: Appendix C does not reproduce them.

Table D.1: The checklist levels and their point values.

$$\text{Coverage} = 100 \times (\text{sum of points}) \div (3 \times \text{number of applicable sub-requirements})$$

Round once, at the point of calculation. The five bands in Section D.4 describe the result rather than produce it: a figure of 68 is read as substantial with only minor gaps, but it is never reached by choosing that phrase.

No checklist entry is adjusted in order to move the calculated figure. If the calculation contradicts a rater's impression of the area, the disagreement is recorded as a comment, since it is evidence about the instrument rather than about the policy.

Every rating below Fully addressed carries a note: either the policy wording quoted, or the single word absent. The note allows a score to be traced back to the text, and it turns a disagreement between two raters into something that can be examined rather than merely counted.

Calibration precedes any live use of the checklist. Two steps are taken, and both are recorded.

- Acceptance test. The two worked examples in Part 2 are scored through the checklist, and the figures that result are recorded in Sections D.8 and D.9 as the reference scorings. Neither extract reaches the coverage band its section once named, because both are short and Requirement 8 carries twenty-four applicable sub-requirements; that is a property of the extracts rather than of the point values, and no point value is adjusted in order to move it. Should the extracts later be replaced with longer ones, the reference scorings are recalculated before any live run and the recalculation is recorded.
- Rater calibration. Every rater, models included, scores both worked examples before scoring any live policy, and agreement with the reference scores is recorded and reported. Divergence found at calibration is a fault in the instrument, to be repaired before live data exists.

D.3 Layer two: the four criteria

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.2: The four criteria and their weights.

Of the four criteria, regulatory coverage is not judged at all: the figure calculated in Section D.2 is entered as it stands and is not adjusted afterwards. The other three are scored against the anchors set out below.

Accuracy. This criterion is anchored in counted defects. A defect is one of four things, and nothing else: an obligation the standard does not contain; a sub-requirement number attached to the wrong obligation; a parameter drawn from a superseded version of the standard; or a claim that a sub-requirement says something it does not. Defects are counted for the requirement area and listed as findings.

Band	Accuracy anchor
81 to 100	No defect. Every cited sub-requirement resolves to text that says what the clause claims, and parameters match version 4.0.1.
61 to 80	No invented obligation. At most one wrong number or superseded parameter, of a kind an assessor would correct without changing what the control does.
41 to 60	Several wrong numbers or superseded parameters, none of which invents an obligation.
21 to 40	One invented or materially misrepresented obligation, or a wrong number repeated often enough to mislead an untrained reader.
0 to 20	Control statements substantially wrong, citations largely failing to resolve, and a document that would misdirect a compliance effort.

Table D.3: Accuracy anchors.

Vagueness is not an inaccuracy. A policy that says little says little that is wrong, and it is penalised under coverage and under enforceability instead. A clause that restates an obligation in weaker terms than the standard uses is likewise a coverage finding and not an accuracy finding, because nothing asserted is false.

Proportionality and scope fit. This criterion asks whether the controls could be operated by a two-person security function using capabilities the scenario states exist, and whether the policy correctly reflects a cardholder data environment in which no primary account number rests on the organisation's systems.

Band	Description
81 to 100	Every control is operable by the two-person function using capabilities the scenario states exist. Scope is described consistently with a cardholder data environment holding no primary account number. No control assumes a capability the scenario lacks.
61 to 80	Controls are broadly operable. There is isolated unresolved wording about scope, or a control assuming a modest capability the scenario does not state.
41 to 60	Several controls assume resources or systems the scenario does not support, or scope statements stay general where the scenario is specific.
21 to 40	The policy reads as though written for a materially different organisation. Scope claims conflict with the scenario.
0 to 20	Scope is fundamentally misdescribed, for example by assuming card numbers are stored. The controls could not be operated as written.

Table D.4: Proportionality and scope fit anchors.

A policy mandating a round-the-clock security operations centre for a sixty-person merchant scores poorly here even where every clause is technically compliant.

Enforceability and clarity. The test is whether a named person could be held to a stated action at a stated frequency.

Band	Description
81 to 100	Every obligation has an owner, and a frequency where one applies, and is worded so that an assessor could test it. Exceptions carry an approver and a time limit.
61 to 80	Most obligations are testable and owned. Isolated vague terms remain.
41 to 60	Testable and untestable obligations are mixed. Recurring clauses have no owner or no frequency.
21 to 40	Wording is mostly untestable, relying on terms such as appropriate and regularly. Ownership is general or absent.
0 to 20	No identifiable owner, cadence or testable statement anywhere in the

Band	Description
	requirement area.

Table D.5: Enforceability and clarity anchors.

D.4 Bands

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.6: Band descriptors.

One rule governs the choice, and it applies to accuracy, proportionality and enforceability alike. Enter at the midpoint of the band, which is taken as 90, 70, 50, 30 and 10, reading down from the highest band. Move in steps of five, once for each factor the rater can cite as evidence. Do not leave the band unless its written description no longer fits.

A policy that does not address a requirement area in any form is scored in the 0 to 20 band for it, not left blank. A blank cell in the scoring record means the rater did not reach that area, which is a different thing and is recorded as such.

D.5 Aggregation

Requirement-area score = (coverage × 0.35) + (accuracy × 0.25) + (proportionality × 0.20) + (enforceability × 0.20)

Policy-level score = the arithmetic mean of the four requirement-area scores

Rounding happens once, and only at the two points named above; intermediate values are carried unrounded. Requirement areas are never weighted against one another.

D.6 Findings, tags and severity

Every finding carries a tag and a severity, and no finding is left untagged. Where a finding genuinely spans two dimensions, both tags are recorded.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.7: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place
Major	The same for an item in milestones 4 to 6; or an obligation in milestones 1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.8: Severity grades.

D.7 How to score

The sequence is the same for every rater, human or model, and is followed in order for each requirement area.

1. Read the requirement text for the area at Appendix C.
2. Read the policy once, all the way through.
3. Complete the checklist, attaching to every rating below Fully addressed either the policy wording quoted or the word absent.
4. Count and list the accuracy defects.
5. Score proportionality and enforceability against their descriptions, entering at the band midpoint and moving in cited steps of five.
6. Record every finding with its sub-requirement, its tag and its severity.
7. Only then read the calculated coverage figure and complete the criterion sheet.

Four standing rules apply throughout.

1. Score the policy in front of you, not the policy you would have written. A different but defensible control is not a finding.
2. An applicable sub-requirement the policy does not address is a gap, whether or not the organisation would find it easy to comply. A sub-requirement absent from Appendix C, because it is addressed to service providers or because its obligation is met in configuration, is not a gap.
3. Record a finding for every gap, weakness or inaccuracy. A score with no findings behind it cannot be interrogated later.
4. Do not adjust a score to reconcile it with another rater. Disagreement between raters is data.

Model raters receive the identical instrument as a form to complete, with instructions on output format and no invitation to add commentary. The completed checklist is data twice over: it is the model's audit, and it is a record of how the model scores.

Both examples were constructed rather than drawn from a model output. They concern Requirement 8 and exist to anchor the bands. The headline comparison of the study sets a model's score against a human's for the same policy and requirement area, and if the two anchor differently, that comparison measures disagreement about the rubric rather than about the policy. Every rater scores both before scoring any live policy.

D.8 A worked example, weak extract

8. Access and Authentication. NorthPay shall maintain strong authentication controls in line with PCI DSS Requirement 8. All users shall have appropriate access credentials. Passwords shall be strong and changed regularly. Multi-factor authentication shall be used where appropriate. Access shall be reviewed periodically. The IT function is responsible for this policy.

Criterion	Score	Reasoning
Checklist total	9 of 72 points	Nine of the twenty-four applicable sub-requirements earn a single point each: 8.1.1, 8.1.2, 8.2.1, 8.3.1, 8.3.6, 8.3.9, 8.4.1, 8.4.2 and 8.4.3. In every case the topic is mentioned but the obligation is not stated in a form an assessor could test. The remaining fifteen are absent. The sentence "Access shall be reviewed periodically" earns nothing here, since that obligation is 7.2.4 and sits outside Requirement

Criterion	Score	Reasoning
		8.
Regulatory coverage	13	Entered from the calculation at Section D.2: $100 \times 9 \div 72 = 12.5$, rounded once to 13. No judgement is applied to this figure. Unique identification, password strength and multi-factor authentication are gestured at; the account lifecycle at 8.2, the password parameters at 8.3.6, the change interval at 8.3.9 and the application and system accounts at 8.6 are not addressed at all.
Accuracy	90	Midpoint of the 81 to 100 band, with no factor cited that would move it. There is no defect of any of the four kinds set out at Section D.3: nothing is invented, no number is misattributed, no parameter is drawn from a superseded version, and no claim is made that a sub-requirement says something it does not. That so vague an extract scores well here is deliberate rather than accidental, since vagueness is penalised under coverage and under enforceability instead.
Proportionality and scope fit	70	Midpoint of the 61 to 80 band. Nothing in the extract is disproportionate and no control assumes a capability NorthPay lacks, which on its own would argue for the band above. It does not reach that band because the description there requires scope to be stated consistently with a cardholder data environment holding no primary account number, and this extract states no scope at all. The policy would read identically for a bank, which avoids the question of scope fit rather than answering it.
Enforceability and clarity	30	Midpoint of the 21 to 40 band. The terms "where appropriate", "regularly" and "periodically" are not testable. No frequency is given, ownership stops at "the IT function", and no review cadence is stated. An assessor could not verify compliance against this wording.

Table D.9: The first worked example, scored.

$$\text{Requirement-area score} = (13 \times 0.35) + (90 \times 0.25) + (70 \times 0.20) + (30 \times 0.20) = 47$$

D.9 A worked example, stronger extract

8.1 Every individual with access to a system connected to or impacting the cardholder data environment is assigned a unique identifier before access is granted. Shared, group and generic accounts are prohibited except where an exception is approved in writing by the Information Security Manager, limited to a stated period, and attributable to an individual (8.2.1, 8.2.2).

8.2 Accounts for leavers are disabled on the last working day and removed within five working days. Accounts inactive for 90 days are disabled automatically (8.2.5, 8.2.6). Accounts used by third parties for remote support are enabled only for the period needed and monitored while in use (8.2.7). The Information Security Manager reviews all accounts with access to systems connected to the cardholder data environment every six months, and management records that the access remains appropriate (7.2.4).

8.3 Passwords are a minimum of 12 characters, contain both numeric and alphabetic characters, and are changed at least once every 90 days unless the account is subject to dynamic access analysis (8.3.6, 8.3.9).

8.4 Multi-factor authentication is enforced through the identity provider for all non-console administrative access, for all remote access originating outside the corporate network, and for all access into systems connected to the cardholder data environment (8.4.1, 8.4.2, 8.4.3).

8.5 Multi-factor authentication systems are configured so that they cannot be bypassed, require at least two distinct factors, and are not susceptible to replay (8.5.1).

Ownership: Information Security Manager. Review: annually, or on significant change to the identity provider.

Criterion	Score	Reasoning
Checklist total	33 of 72 points	Eight sub-requirements are fully addressed and score three each: 8.2.1, 8.2.6, 8.2.7, 8.3.6, 8.3.9, 8.4.1, 8.4.2 and 8.4.3. Four are largely addressed and score two: 8.1.1, 8.1.2, 8.2.2 and 8.2.5. One is partially addressed and scores one, 8.3.1, because the general obligation to authenticate every user through a permitted factor is never stated. The remaining eleven are absent: 8.2.4, 8.2.8, 8.3.3, 8.3.4, 8.3.5, 8.3.7, 8.3.8, 8.3.11, 8.6.1, 8.6.2 and 8.6.3.
Regulatory coverage	46	Entered from the calculation at Section D.2: $100 \times 33 \div 72 = 45.8$, rounded once to 46. The extract is specific where it speaks, but it speaks to thirteen of the twenty-four applicable sub-requirements. Requirement 8.6, the application and system accounts, is absent altogether. One near-miss belongs here rather than under accuracy: 8.2.5 requires access for terminated users to be revoked immediately, and "disabled on the last working day, removed within five working days" is not the same commitment.
Accuracy	90	Midpoint of the 81 to 100 band. Sub-requirement numbers

Criterion	Score	Reasoning
		are correctly attributed, including the cross-reference to 7.2.4 for the six-monthly review, which sits in Requirement 7; citing it from a Requirement 8 section is correct practice and not an error. The twelve-character minimum and the ninety-day interval match version 4.0.1 rather than the version 3.2.1 figures, which is the error this criterion most often catches. The citation of 8.5.1 is likewise not a defect, since the obligation it names is real even though Appendix C does not carry that sub-requirement.
Proportionality and scope fit	90	Midpoint of the 81 to 100 band. Enforcement is placed on the identity provider, which the scenario states exists and is capable of it, rather than on a control the organisation does not have. The six-month review interval is realistic for a two-person function, and nothing in the extract assumes that a primary account number rests on a NorthPay system. The repeated phrase "systems connected to or impacting the cardholder data environment" is never resolved into a list, which appears to be a weakness of clarity rather than of scope fit, and it is penalised under the next criterion.
Enforceability and clarity	80	Entered at the midpoint of the 61 to 80 band and moved twice in steps of five: once for the named owner with a stated review cadence, and once for exceptions that carry both an approver and a time limit. Frequencies are stated and the parameters are numerical. It does not enter the band above because several applicable obligations are absent, and because "removed within five working days" carries no stated consequence for failure.

Table D.10: The second worked example, scored.

$$\text{Requirement-area score} = (46 \times 0.35) + (90 \times 0.25) + (90 \times 0.20) + (80 \times 0.20) = 73$$

Part 2 Reviewer Response Capture Form

D.10 Scope

The Reviewer Response Capture Form was used to record reviewer feedback from the policy review and were expected to return fully completed response forms. The form contains the full scoring criteria documented in Part 1 of this appendix. It was issued to the reviewers along with the scenario brief at Appendix A, the requirement extract at Appendix C, and the policies under review.

During the review each reviewer completed one form for each policy they reviewed, so each reviewer returned four completed forms.

By design, the sheet does not capture any personal information in scope for the UK GDPR that could identify the reviewer by name. Reviewers were also not told which model produced the policy.

Reviewers were expected to follow the steps below, in the order stated, for each requirement area:

1. Read the requirement text at Appendix C.
2. Read the policy once, all the way through.
3. Record the findings with their tags and severities.
4. Enter the four criterion scores last.

D.11 The instrument in brief

Each policy is scored one requirement area at a time, out of 100, on four weighted criteria. A requirement-area score is the weighted sum of those four. The policy-level score is the mean of the four requirement-area scores, which keeps a weak area visible rather than letting a strong one mask it.

Criterion	What it measures	Weight
Regulatory coverage	The extent to which the policy addresses the applicable PCI DSS v4.0.1 sub-requirements for the requirement area, with no material control omitted	35
Accuracy	The correctness of the control statements, and the absence of hallucinated, misattributed or outdated requirements	25
Proportionality and scope fit	Whether the controls are proportionate to the organisation's size and validation scope, and whether the policy claims a scope the scenario does not support	20

Criterion	What it measures	Weight
Enforceability and clarity	Plain, testable and actionable wording, with defined roles, responsibilities and a stated review cadence	20

Table D.11: The four criteria and their weights.

$$\text{Requirement-area score} = (\text{coverage} \times 0.35) + (\text{accuracy} \times 0.25) + (\text{proportionality} \times 0.20) + (\text{enforceability} \times 0.20)$$

Apply the band descriptions below to each criterion before weighting. Enter at the midpoint of the band, then move in steps of five, once for each factor you can point to in the policy. Never leave a cell blank. A policy that does not address a requirement area at all is scored in the 0 to 20 band; a blank cell means you did not reach that area, which is a different thing.

Band	Meaning
81 to 100	Comprehensive and specific to the requirement
61 to 80	Substantial, with only minor gaps
41 to 60	Partial coverage with clear gaps
21 to 40	Minimal, or largely generic boilerplate
0 to 20	Absent, or present but incorrect

Table D.12: Band descriptors.

Separately from the scores, tag every gap or weakness you record against one of three control dimensions, and grade its severity. This is what allows the study to report where compliance failures cluster rather than only how large they are. Where a finding genuinely spans two dimensions, record both tags. No finding is left untagged.

Tag	Definition	Typical instance
T, technical	Controls implemented in or enforced by systems	Multi-factor authentication for access into the cardholder data environment; audit log retention periods
A, administrative	Governance, roles, process and oversight	Security awareness training; third-party due diligence under 12.8; ownership of incident response
L, legislative	Obligations arising from law rather than from PCI DSS	UK GDPR breach notification, lawful basis and retention where personal data and cardholder data overlap

Table D.13: Control dimension tags.

Severity	Definition
Critical	An applicable sub-requirement in Prioritized Approach milestones 1 to 3 is not addressed, or is stated so wrongly that an assessor would record it as not in place
Major	The same for an item in milestones 4 to 6; or an obligation in milestones

Severity	Definition
	1 to 3 that is present but weaker than the standard requires
Minor	Defects in clarity, ownership or cadence that leave the obligation itself intact

Table D.14: Severity grades.

D.12 Calibration before you begin

Before scoring any policy, score both worked examples in Sections D.8 and D.9 of the Policy Evaluation Rubric, and enter your four criterion scores for each below.

Note that both cover PCI DSS Requirement 8 only and score each extract exactly as you would score a live policy, then enter your four criterion scores and the resulting area score in Table D.15 below.

Do not estimate the coverage figure. Rate every applicable Requirement 8 sub-requirement 0 to 3 using the four levels defined in Section D.2 of the rubric, add up the points, and calculate:

$$\text{Coverage} = 100 \times \text{total points} \div 72$$

Requirement 8 carries twenty-four applicable sub-requirements, so 72 points is the maximum.

Worked example	Coverage	Accuracy	Proportionality	Enforceability	Area score
First, Section D.8					
Second, Section D.9					

Table D.15: Calibration scores.

D.13 Scoring

Policy code under review: _____ Date completed: _____

Reviewer identifier: _____ (assigned by the researcher; please do not write your name on this sheet)

D.13.1 Requirement 7, restrict access to system components and cardholder data by business need to know

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage		
Accuracy		
Proportionality and scope fit		
Enforceability and clarity		
Requirement-area score		

Table D.16: Requirement 7, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity

Table D.17: Requirement 7, findings.

D.13.2 Requirement 8, identify users and authenticate access to system components

Complete the coverage checklist at Section D.13.5 before entering a figure for regulatory coverage below. The coverage score is the checklist result, not a separate judgement.

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage		
Accuracy		
Proportionality and scope fit		
Enforceability and clarity		
Requirement-area score		

Table D.18: Requirement 8, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity

Table D.19: Requirement 8, findings.

D.13.3 Requirement 10, log and monitor all access to system components and cardholder data

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage		
Accuracy		
Proportionality and scope fit		
Enforceability and clarity		
Requirement-area score		

Table D.20: Requirement 10, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity

Table D.21: Requirement 10, findings.

D.13.4 Requirement 12, support information security with organisational policies and programmes

Criterion	Score, 0 to 100	Evidence or comment
Regulatory coverage		
Accuracy		
Proportionality and scope fit		
Enforceability and clarity		
Requirement-area score		

Table D.22: Requirement 12, criterion scores.

Sub-requirement	What is missing, wrong or unenforceable	Tag	Severity

Table D.23: Requirement 12, findings.

D.13.5 Requirement 8 coverage checklist

Rate every sub-requirement below, then add the points and enter the result as regulatory coverage at Section D.13.2. Points are 3 fully addressed, 2 largely addressed, 1 partially addressed and 0 not addressed. Coverage = $100 \times \text{total points} \div 72$. Every rating below fully addressed carries a note: either the policy wording quoted, or the single word absent.

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.1.1 Requirement 8 policies documented, current, in use, known to affected parties			
8.1.2 Roles and responsibilities documented, assigned and understood			
8.2.1 Unique ID assigned to every user before access is allowed			
8.2.2 Group, shared or generic IDs used only by managed exception			
8.2.4 Additions, deletions and changes to IDs authorised and limited to approved privileges			
8.2.5 Access for terminated users revoked immediately			
8.2.6 Inactive accounts removed or disabled within 90 days			
8.2.7 Third-party remote support accounts enabled only when needed and monitored			
8.2.8 Re-authentication required after 15 minutes idle			
8.3.1 All user and administrator access authenticated by a permitted factor			
8.3.3 Identity verified before an authentication factor is changed			
8.3.4 Invalid authentication attempts limited by logout			
8.3.5 First-time and reset passwords set uniquely and changed on first use			
8.3.6 Password complexity, minimum 12 characters, numeric and alphabetic			

Sub-requirement	Level	Points	Evidence note, quoted wording or absent
8.3.7 No reuse of any of the last four passwords			
8.3.8 Authentication policies documented and communicated to all users			
8.3.9 Password changed at least every 90 days, or dynamic access analysis			
8.3.11 Tokens, smart cards and certificates assigned to an individual and protected			
8.4.1 MFA for all non-console administrative access into the CDE			
8.4.2 MFA for all non-console access into the CDE			
8.4.3 MFA for all remote access originating outside the network			
8.6.1 Interactive login by system or application accounts controlled			
8.6.2 No hard-coded passwords in scripts, configuration files or code			
8.6.3 System and application account passwords protected and changed periodically			

Table D.24: Requirement 8, coverage checklist.

D.14 Overall judgement

Answer in as much or as little space as the question deserves; the boxes expand.

Question	Response
Would this policy survive a real PCI DSS assessment, and what would you challenge first?	
Anything that reads as compliant on the surface but would not hold.	
Any requirement or sub-requirement missed, misstated or invented.	
Could an organisation of sixty-one people, with a security function of two, realistically adopt and enforce this policy as written?	
Anything else worth recording.	

Table D.25: Overall judgement.

D.15 Reviewer background and return

For context only. No employer is recorded, and none should be written here.

Field	Response
Principal field of work	
Years of experience with PCI DSS	
Currently or formerly a Qualified Security Assessor	

Table D.26: Reviewer background.

Please return the completed form to the researcher by the date given in the covering note.